

Security Requirements: Best Practices & Examples

1. Introduction

This document outlines common security requirement pitfalls. It contrasts vague, unverifiable requirements ('Bad') with specific, testable ones ('Good'). Use this to guide the refinement of security specifications for the Employee Portal App.

2. Authentication Requirements

BAD EXAMPLE: "The system must have strong passwords."

WHY IT FAILS: 'Strong' is subjective. Developers might interpret this as just 6 characters.

GOOD EXAMPLE: "The system must enforce a password policy requiring a minimum length of 12 characters, containing at least one uppercase letter, one lowercase letter, one number, and one special character. Passwords must be hashed using Argon2id or bcrypt."

3. Data Protection (Encryption)

BAD EXAMPLE: "The application must be secure and encrypt data."

WHY IT FAILS: Does not specify which data, which state (at rest/in transit), or which algorithm.

GOOD EXAMPLE: "All Sensitive PII (Personally Identifiable Information) stored in the database must be encrypted at rest using AES-256. All data in transit must use TLS 1.3 only."

4. Access Control

BAD EXAMPLE: "Only admins can access settings."

WHY IT FAILS: Ambiguous. Who is an admin? How is it enforced?

GOOD EXAMPLE: "The system must implement Role-Based Access Control (RBAC). Only users assigned the 'System_Administrator' role are permitted to access the '/settings' endpoint. Access attempts by unauthorized roles must result in a HTTP 403 Forbidden response."

5. Auditing and Logging

BAD EXAMPLE: "The system should log errors."

Security Requirements: Best Practices & Examples

WHY IT FAILS: 'Should' is not mandatory. Doesn't specify what to log.

GOOD EXAMPLE: "The system **MUST** log all failed authentication attempts, privilege escalation events, and access to sensitive data. Logs must include: Timestamp (UTC), Source IP, User ID, and Event Type. Logs must not contain plain-text passwords."